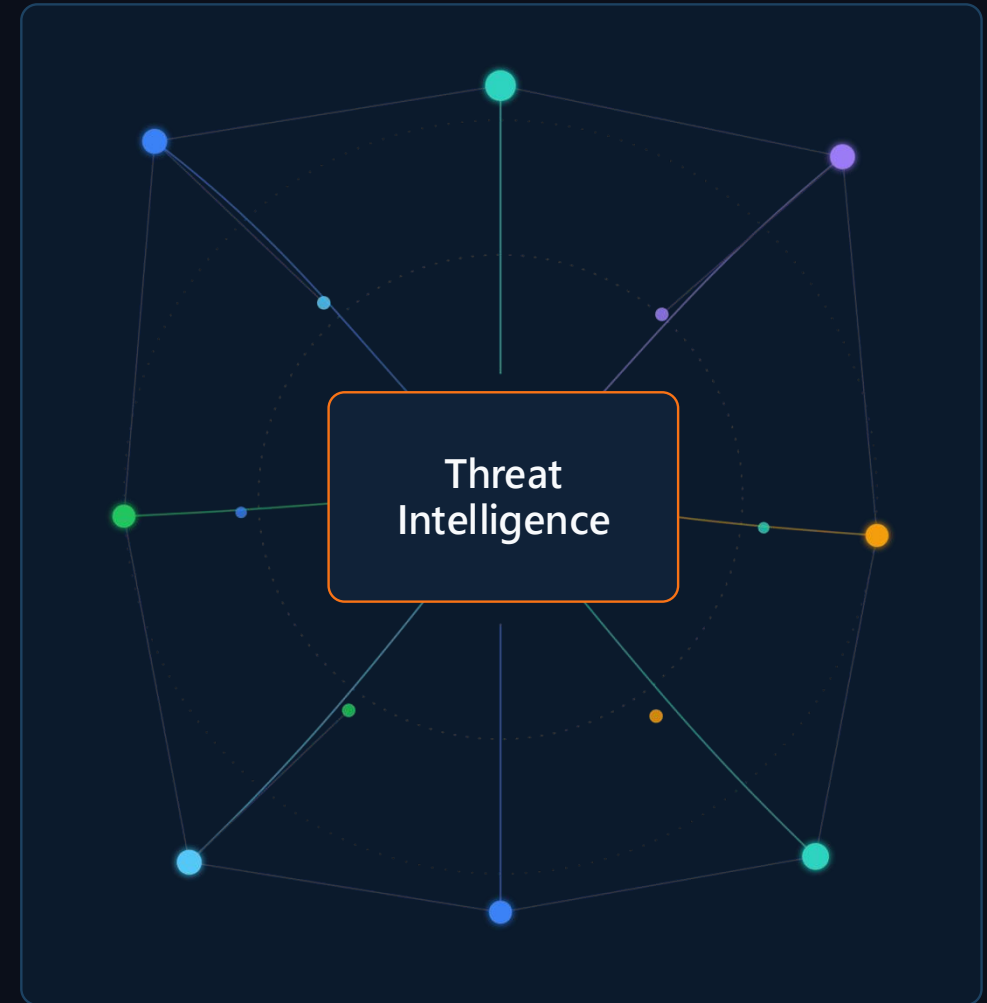


從 Honeypot 到 Threat Intelligence

T-Pot 與 AI 驅動的威脅分析實戰

把蜜罐資料轉成可以調查、分享與採取行動的威脅情報。



蔡笙宇

現為 The Honeynet Project Taiwan Chapter 成員，就讀國立暨南國際大學管理學院，自高中時期即投入網路攻擊分析、威脅情資，蒐集於2025年越級挑戰大專資訊創新競賽獲得大專資訊安全組佳作，曾於 g0v 主辦的面海松 (FTO) 進行演講，近年專注於 T-Pot Honeynet 平台建置與維運，透過分散式誘捕系統蒐集真實世界攻擊活動，研究攻擊者行為模式及新興威脅趨勢。

證照：

ITS Python
Cisco
Cybersecurity
ITS
Cybersecurity

社群參與：

2024 GDG DevFast 開發者大會台南場
2025 泰國亞洲資安展 (Cybersec Asia)
2025 面海松 Facing the Ocean





高偉碩

- 來毅數位科技股份有限公司 雲端資安架構師
- 台灣數位安全聯盟 資安顧問
- The HoneyNet Project 台灣分會成員
- 國際資訊安全組織台灣高峰會 講師
- 科技部SP-ISAC 計畫資安教育訓練 講師

證照：

CCNA

CCNP

CEH

CCSK

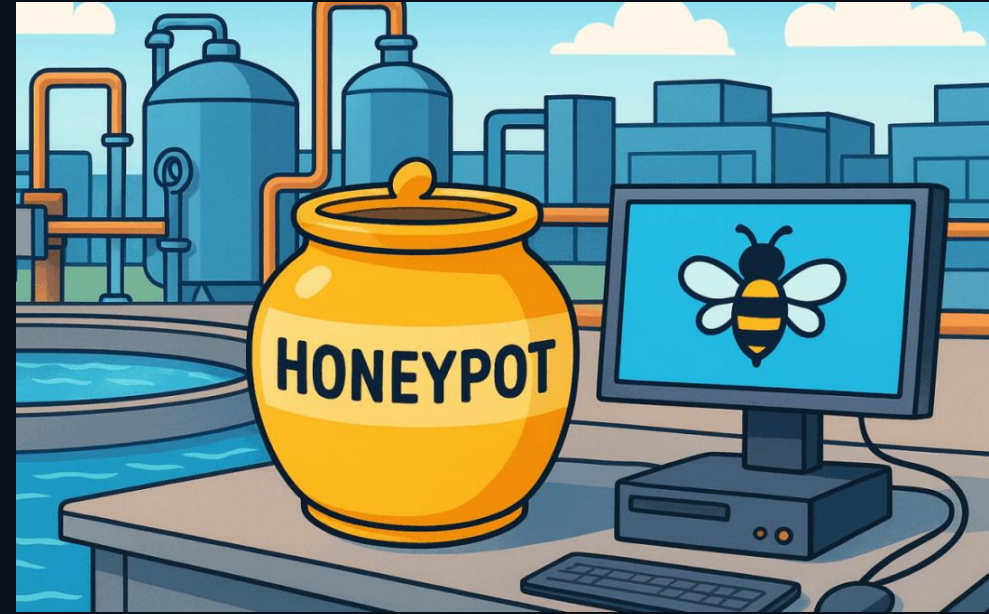
ISO 27001:2022

-什麼是T-Pot Honeynet?

T-Pot Honeynet 是由 Deutsche Telekom 開發的一套開源蜜罐平台，主要用於網路攻擊行為的收集與分析。它將多種 Honeypot、日誌收集工具與資料分析平台整合在同一系統中，讓使用者能夠快速建置完整的攻擊監測環境。

T-Pot 的設計目標是讓研究人員或資安人員可以：

- 模擬多種弱點服務吸引攻擊
- 收集攻擊者的行為與工具
- 分析攻擊趨勢與威脅模式
- 建立自己的威脅情資 (CTI)



-什麼是T-Pot Honeynet?

Honeypot 與 Honeynet 概念Honeypot (蜜罐) 是一種主動式防禦技術，透過模擬具有弱點的服務來吸引攻擊者。攻擊者在不知情的情況下與蜜罐互動，所有行為都會被完整記錄。

Honeynet 則是由多個 Honeypot 組成的網路架構，模擬更接近真實企業環境的系統。

常見分類：

- 低互動 (Low-interaction)：模擬服務，安全但資料較少
- 高互動 (High-interaction)：真實系統，資料多但風險較高

主要用途：

- 攻擊研究
- 威脅情報蒐集
- 漏洞分析

-T-Pot 的核心特色

T-Pot 最大特色在於「高度整合」與「自動化部署」：

- 多種 Honeypot 一鍵部署 (SSH、HTTP、ICS、IoT 等)
- 採用 Docker 容器技術，方便管理與隔離
- 內建完整 ELK Stack (Elasticsearch、Logstash、Kibana)
- 即時視覺化攻擊行為
- 支援多種 Web Dashboard
- 自動更新與模組擴充

此外，T-Pot 也支援遠端存取與集中化管理，適合教學與研究用途。

-系統架構概覽

T-Pot 採用分層架構設計，主要分為以下幾層：

Honeypot 層：

- 提供各種模擬服務
- 接收攻擊流量

Log 收集層：

- 使用 Filebeat 或 Logstash 收集日誌

資料處理層：

- Logstash 進行解析 (Parsing) 與轉換

儲存層：

- Elasticsearch 負責索引與搜尋

視覺化層：

- Kibana 提供圖表與 Dashboard

整體透過 Docker Compose 進行協調與部署。

-常見 Honeypot 類型

T-Pot 內建多種 Honeypot，每種對應不同攻擊面：

- Cowrie：

模擬 SSH/Telnet，記錄登入與指令操作

- Dionaea：

收集惡意程式與 exploit

- Conpot：

模擬工控系統（ICS/SCADA）

- Heralding：

記錄帳號密碼暴力破解

- Honeytrap：

通用型網路服務誘捕器

- ElasticPot：

模擬未授權 Elasticsearch

這些 Honeypot 能同時運作，形成多層防禦與觀測。

-資料收集與處理流程

當攻擊發生時，資料流程如下：

攻擊者掃描或連線至 Honeypot

Honeypot 回應並誘導攻擊者互動

記錄內容包含：

- IP 位址

- 登入帳密

- 執行指令

- 上傳惡意檔案

日誌透過 Filebeat 傳送

Logstash 進行：

- 資料清洗

- 欄位解析

- 格式統一 (JSON)

存入 Elasticsearch

由 Kibana 即時顯示

-ELK Stack 在 T-Pot 中的角色

ELK Stack 是資料分析核心：

Elasticsearch：

- 高效搜尋引擎
- 支援大規模資料索引
- 可進行複雜查詢

Logstash：

- 支援多種資料來源
- 可進行轉換與過濾
- Pipeline 設計彈性高

Kibana：

- 提供視覺化儀表板
- 可自訂圖表（圓餅圖、折線圖、地圖）
- 支援即時監控

-攻擊可視化

T-Pot 的 Dashboard 能呈現：

- 全球攻擊來源地圖 (GeoIP)
- 攻擊次數時間序列分析
- 不同 Honeypot 的攻擊比例
- 常見密碼與帳號排行
- 攻擊類型 (Brute Force、Exploit 等)
- 惡意命令 (如 wget、curl)

這些視覺化結果可幫助快速判斷威脅趨勢。

-部署方式

部署方式包括：

Bare Metal (實體機)

- 最佳效能

- 適合長期監控

虛擬機 (VMware / VirtualBox)

- 適合測試與教學

雲端部署 (AWS / GCP / Azure)

- 可對外公開吸引攻擊

- 易於擴展

基本需求：

CPU：4 cores 以上

RAM：8–16GB

儲存空間：100GB+ (因為 log 很多)

-安全性與隔離設計

T-Pot 在設計上非常重視安全：

- 每個 Honeypot 獨立 Docker Container
- 使用防火牆限制流量
- 防止攻擊者跳板攻擊 (Pivoting)
- 建議部署於 DMZ 或隔離網段
- 不建議與企業內網直接連接

此外，可搭配 IDS/IPS 進一步強化安全。

-T-Pot 在 CTI 中的應用

T-Pot 可作為威脅情資來源：

- 收集攻擊 IP 與行為
- 分析攻擊模式 (TTPs)
- 建立黑名單 (Blacklist)
- 整合至 SIEM 系統
- 支援 SOC 分析流程

也可用於：

- 教學實驗
- 滲透測試研究
- 惡意程式分析

-優點與限制

優點：

- 開源免費、社群活躍
- 快速部署（自動化）
- 整合度高（多 Honeypot + ELK）
- 視覺化強大

限制：

- 資源消耗高（CPU / RAM / Storage）
- 初學者學習曲線較高
- 高互動蜜罐存在風險
- 進階攻擊者可能識別蜜罐特徵

因此需要搭配良好網路隔離與監控策略。

你架了一個HoneyPot，然後呢？

問題不是沒有資料，而是沒有快速轉成洞察的方法。

Day 1

哇！有人攻擊我

Day 30

看 5 分鐘 Dashboard

Day 90

系統還在跑，沒人看

為什麼失去價值？

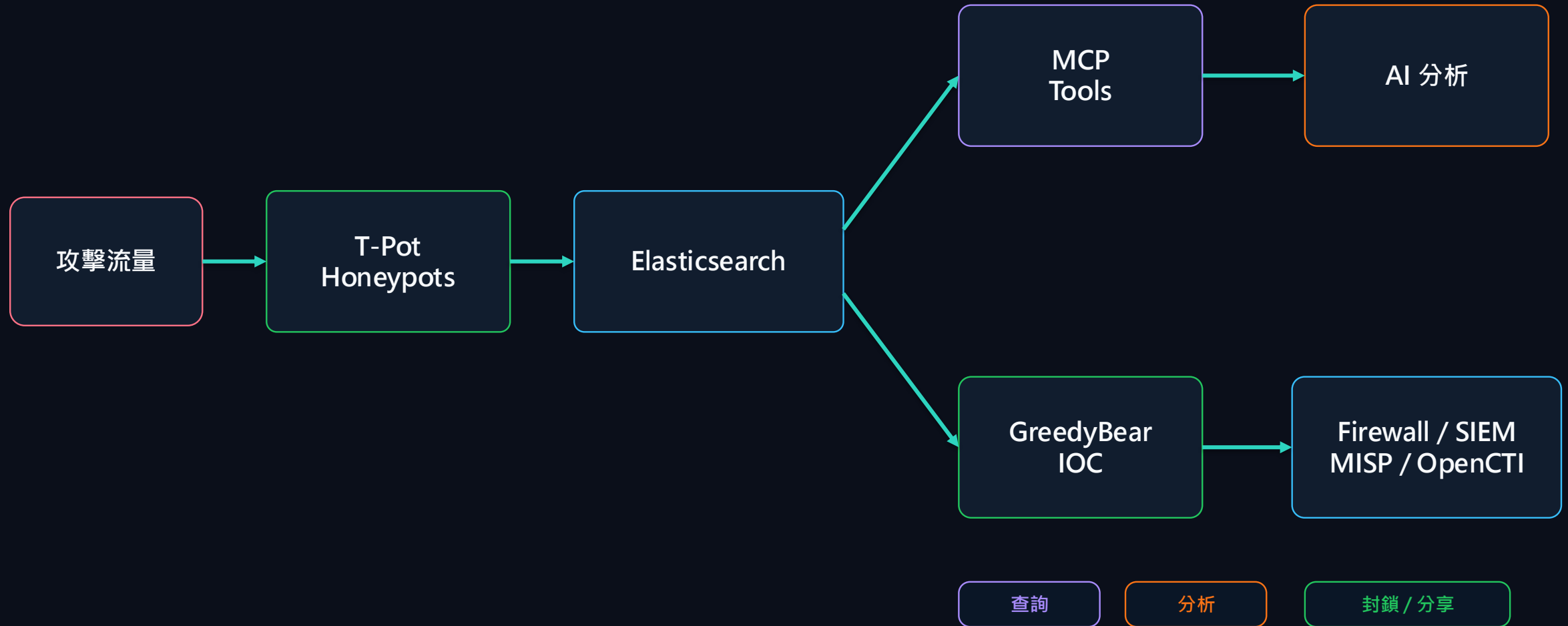
- 查詢門檻高
- 訊號被大量 log 淹沒
- 每天重複相同操作

今天要改變的事

- 自然語言調查
- 固定 schema 知識
- 分析結果直接進入防禦流程

今天建什麼？

一條從攻擊流量到 AI 分析與防禦行動的完整資料鏈。



全套架構元件

每一層只負責一件事，才能維持可理解、可替換、可擴充。



T-Pot
捕捉攻擊



Elasticsearch
儲存事件



Kibana
視覺探索



GreedyBear
彙整 IOC



MCP Servers
語意工具



Claude
調查與報告



IOC Export
輸出與封鎖



MISP / OpenCTI
情報分享

原版 T-Pot 已經很完整

它解決「捕捉與視覺化」，但還沒有把資料送進行動流程。

原版提供

- 20+ 種 honeypot
- Elasticsearch + Kibana
- Docker Compose 部署
- HIVE / SENSOR 架構
- 預建 Dashboard

缺少的最後一哩

- AI 查詢
- IOC 輸出
- 自動報告
- 資源自適應

PoC 的角色：補上情報化與自動化，而不是重造蜜罐平台。

本 PoC 加了什麼？

把 T-Pot 從觀察平台升級成可行動的威脅情報管線。

穩定運行

Preflight | 動態記憶體 | Suricata 降噪

情報萃取

GreedyBear IOC REST API

AI 調查

11 個語意工具 | Claude Desktop / API

防禦輸出

iptables | pfSense | Wazuh | MISP

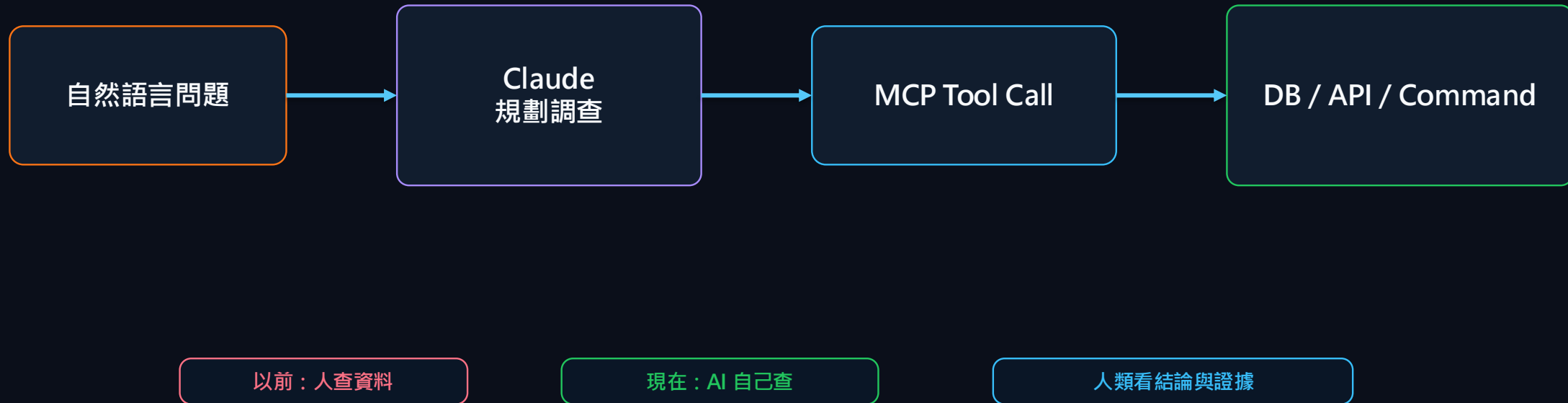
MCP：讓 AI 直接操作工具

不再複製貼上 log，讓 AI 自己規劃查詢。



什麼是 MCP ?

Model Context Protocol 讓模型以一致方式呼叫外部工具。



官方 Elasticsearch MCP

通用、彈性，但 Claude 必須自己知道查什麼欄位。



list_indices

索引清單



get_mappings

欄位 schema



search

任意 DSL 查詢



get_shards

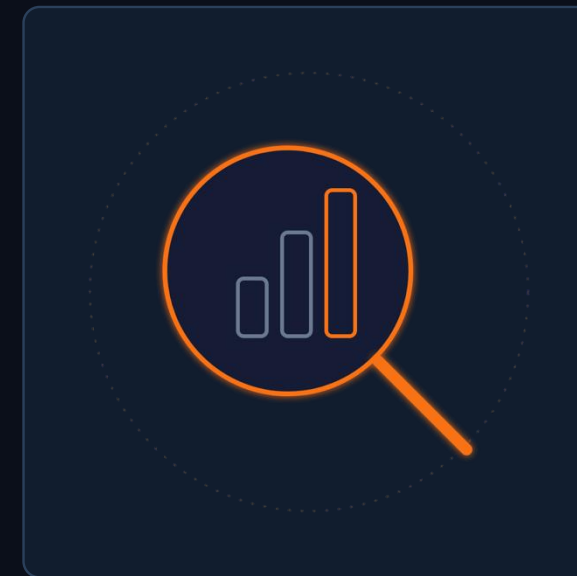
分片狀態

定位

它是一個通用 ES 客戶端，不包含 T-Pot 的欄位陷阱與 SOC 分析語意。

從問答到主動分析

AI 的價值在於規劃調查，而不是生成漂亮摘要。



AI 的角色：從工具到分析師

人力從「查資料」移到「判斷與決策」。

傳統 SOC

告警 → 人工查 ES / SIEM → 整理證據 → 寫報告
→ 決策

AI 驅動

告警 → AI 多工具調查 → 證據化報告 → 人類決策



規劃步驟



跨工具取证



整合推理



輸出建議

一個問題背後的工具鏈

「今天有異常嗎？誰最可疑？為什麼？」



AI 最終輸出

今日摘要 | 最危險攻擊者 | 證據與理由 | 立即行動 | 風險等級

一條調查鏈的成本：人工 vs AI

AI 驅動不是噱頭——省下的是每天都在發生的重複調查。

人工調查 (估算)

30–45 分鐘 / 次

手寫 ES DSL、跨索引查詢
人工交叉比對、整理證據、寫報告
品質依賴個別分析師的經驗



AI 調查鏈 (本機實測)

約 3 分鐘 / 次

自動選工具、五步串聯
含推理與報告生成時間
品質由提示規格固定，可重複

≈ 10 倍的時間差

每天一次深度調查，一年省回約 180 小時的分析人力

基準：五步調查鏈 (總覽 → TOP 3 → 側寫 → 評分 → CVE 對照) ； AI 時間為本機 Claude Desktop 實測。

提示工程：讓 AI 產出可用報告

把角色、步驟與輸出格式說清楚。

差的提示

「看一下今天的攻擊」
→ 一個工具結果，沒有調查鏈

Role

Scope

Steps

好的提示

角色：資深 SOC 分析師
範圍：過去 24 小時
步驟：總覽 → TOP 3 → Profile → Score → CVE
輸出：摘要、最危險 IP、立即行動、風險等級

提示不是文案技巧，而是分析流程的規格。

提示工程的安全邊界

安全分析的第一原則：證據必須可追溯。

Role

指定 SOC / APT 分析角色

Scope

只看明確時間範圍

Evidence

只用 MCP 回傳資料

Format

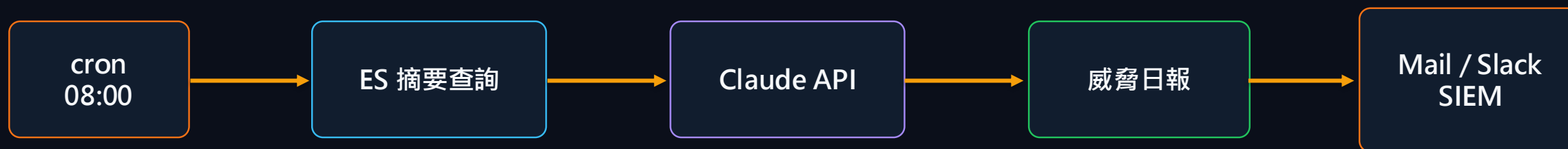
固定報告格式與行動項

禁止事項

不要用模型記憶猜測 IP 歸屬、惡意程度或最新威脅情報。高影響力操作必須由人類確認。

Claude API 定時報告

從互動問答，走向每天自動產出可讀的威脅摘要。



值班交接

高風險 IP

每週趨勢

晨間摘要

AI + IOC : 智慧封鎖決策

不是所有看到的 IP 都應該永久封鎖。

高攻擊次數 + Payload

立即封鎖

高復發率 + Scanner

暫時封鎖 24h

低次數 + 單一 Honeypot

加入觀察

CDN / 研究機構

白名單 / 人工確認

AI 的局限性與最佳實踐

把 AI 放在它擅長的位置：初篩、關聯與說明。

幻覺

只信任工具證據

情報過時

接即時 IOC

誤判

人類確認封鎖

缺乏業務情境

加入白名單 / 例外

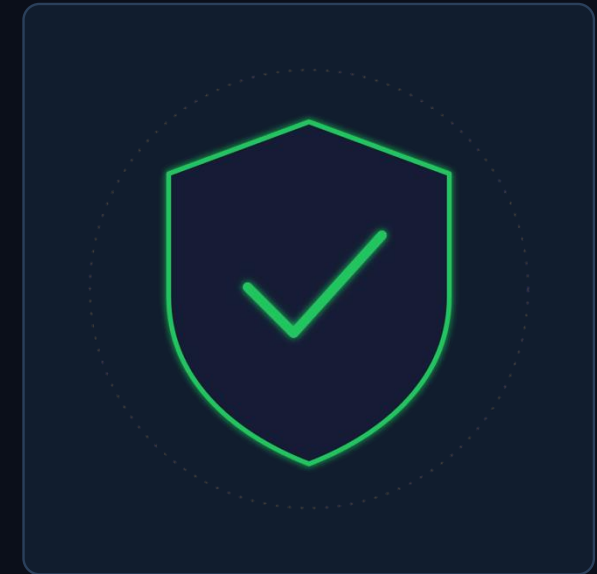
AI：初篩 + 分析 + 建議



人類：決策 + 例外處理

IOC Feed 整合與自動封鎖

情報只有被其他系統使用，才會產生防禦價值。



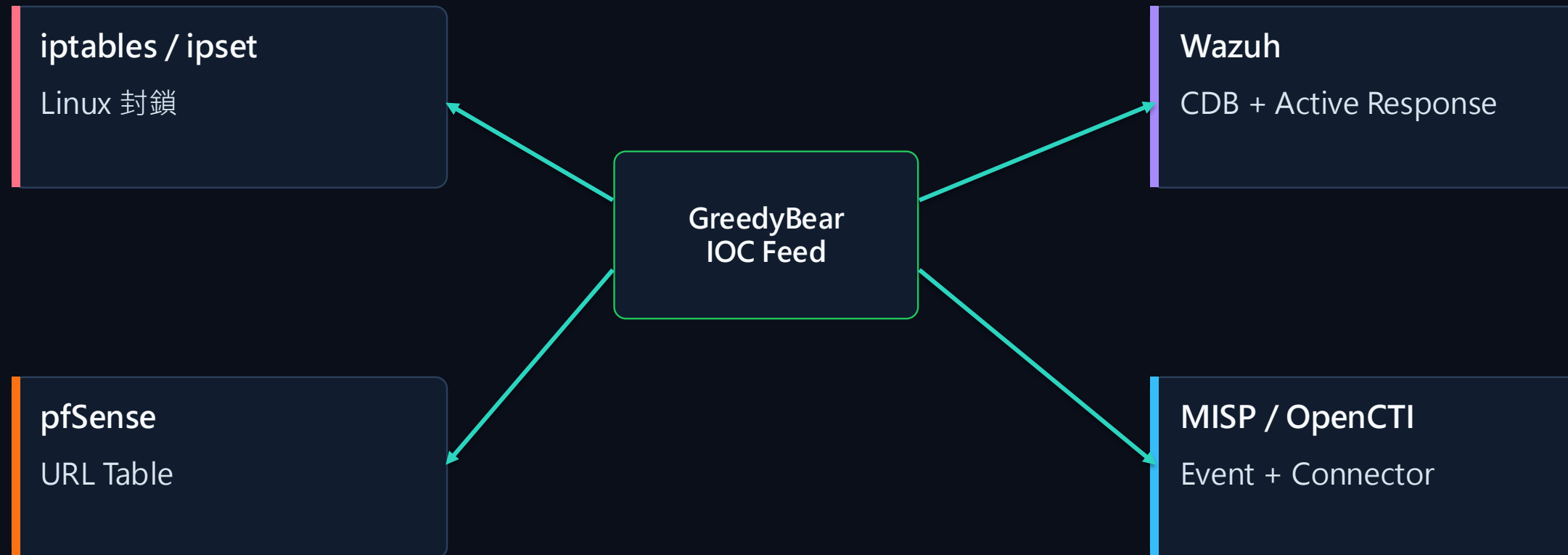
GreedyBear 資料流程

IOC 不直接查 PostgreSQL ; 所有整合都走 REST API 。



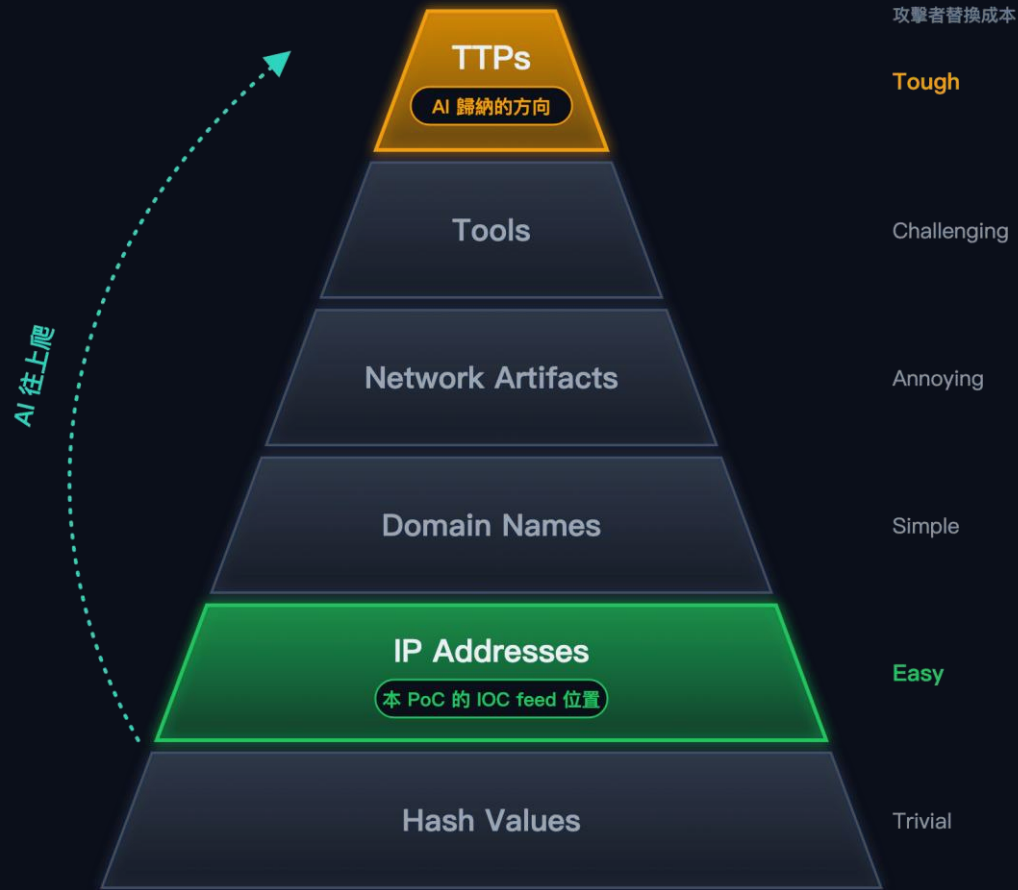
防火牆、SIEM 與情報平台整合

同一份 IOC，同時支援封鎖、偵測與分享。



IOC 的極限：Pyramid of Pain

IP 名單在金字塔底層——所以 AI 的工作是往上爬。



換 IP 零成本

IP 名單很快過期，封鎖只是即時止血；攻擊者換一個跳板就繞過。

行為才難換

post_auth_commands、credentials 捕捉的是攻擊者的「習慣」。

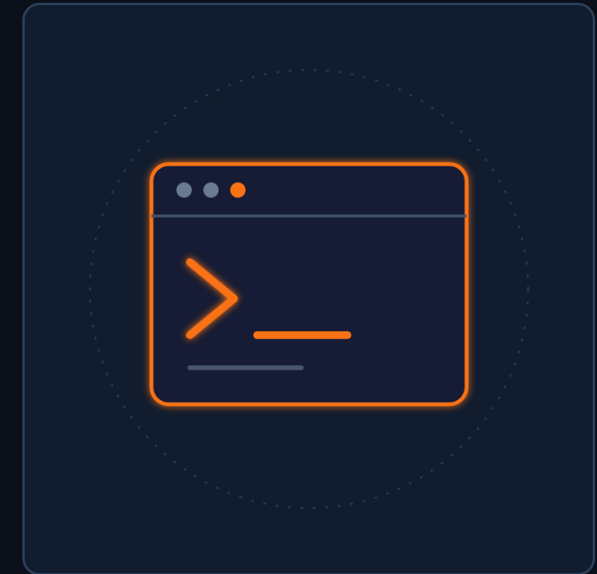
AI 的主場

從指令序列歸納 TTP、對應 MITRE ATT&CK——規則寫不出來的部分。

IP feed 是止血，
TTP 歸納才是長期情報價值。

Live Demo

從「昨晚發生什麼」一路追到具體行動。



Demo 腳本：從總覽到攻擊者側寫

現場只輸入自然語言，Claude 自己選擇工具。



你得到的不是 raw log

而是「它做了什麼、從哪來、威脅分數多少、下一步怎麼處理」。

Demo 腳本：從 CVE 到封鎖建議

把調查結果接回 IOC 與通用 ES 探索。

4

CVE / IDS 告警

get_cve_alerts

5

IOC 智慧分流

永久封鎖 / 觀察

6

通用 ES 探索

indices + search

Demo 主機：真實攻擊資料

截至 2026-07-03 累計，排除測試 IP 後。

381,608

總事件數

130

外部攻擊者 IP

205

GreedyBear IOC

3

大廠掃描來源

#1 34.95.113.255

Google LLC

#2 160.79.104.10

Anthropic, PBC

#3 20.27.177.117

Microsoft

結論：大廠掃描、研究流量與惡意行為會混在一起，不能只靠 IP 名單盲封。

一條 IP 的旅程：34.92.128.245

真實資料：一個 Google 掃描器如何被正確放行，而不是誤封。



同一條管線，該封的封、不該封的放行——這就是「智慧分流」的實際案例。

若換成「高攻擊次數 + 帶 payload」的 IP，同一條線的終點就是立即封鎖

數據取自本機 Elasticsearch / GreedyBear，2026-06-13 ~ 07-03。

總結

把蜜罐資料變成能被 AI 分析、被系統消費、被人類決策使用的情報。



我們解決了什麼問題？

每個技術修正都對應一個實際營運痛點。

資料沒人看

→ AI 主動分析

ES DSL 太難

→ 11 個語意工具

欄位容易用錯

→ 固化 schema 知識

IOC 無法使用

→ 統一輸出腳本

報告依賴人工

→ API + cron

AI 可能誤封

→ 人類最終決策

這條管線，就是情報生命週期

收集 → 處理 → 分析 → 傳播 → 回饋，補上回饋才是完整的 Threat Intelligence。

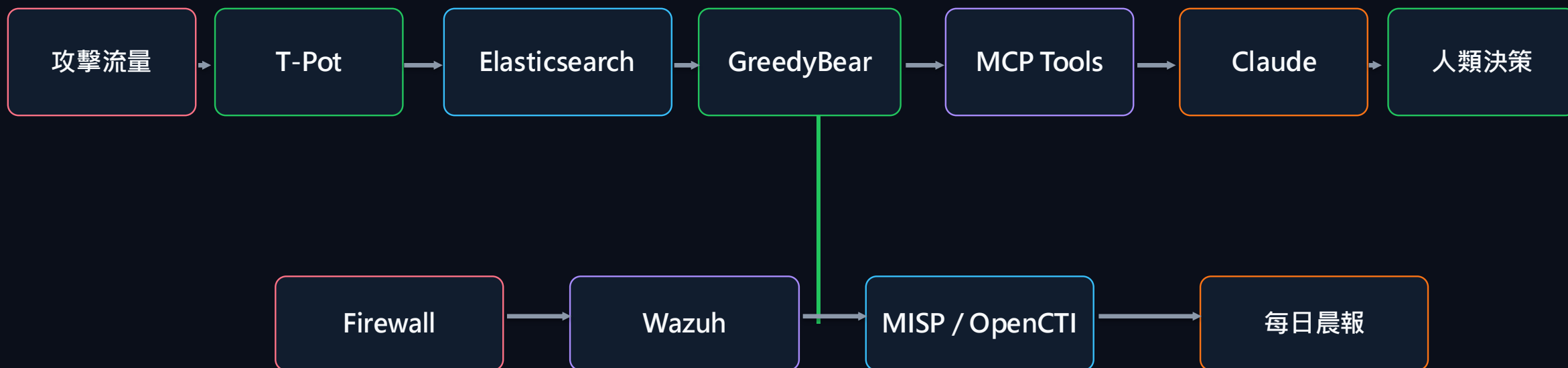


回饋段：定期讀取 ipset 封鎖命中數寫回 Elasticsearch——「封鎖到底有沒有用」用數字回答，並回頭校準 GreedyBear 的 IOC 門檻與 AI 的分流規則。

回饋讓管線變成閉環：情報的價值，由防禦成效來驗證。

完整工具鏈回顧

捕捉、儲存、分析、輸出與決策形成閉環。



更多攻擊資料 → 更好的情報 → 更精準的調查與防禦

Q & A

從 Honeypot 到 Threat Intelligence

AI 做初篩、關聯與建議；
人類做最後決策。

